



Infrastructure Governance Guide for Regulated Organizations

Health Insurance Portability and Accountability Act (HIPAA)

How managed infrastructure is the foundation of every enforceable governance program under HIPAA requirements.

1. HIPAA Physical and Technical Safeguards as Infrastructure Mandate

HIPAA Security Rule Physical and Technical Safeguards are explicitly infrastructure requirements. They cannot be satisfied with policies alone:

- Physical Safeguards (164.310): Facility access controls for systems containing ePHI. Workstation use policies for proper function of workstations. Device and media controls for how hardware and electronic media are handled, moved, reused, and disposed.
- Technical Safeguards (164.312): Access controls including unique user identification, automatic logoff, and encryption. Audit controls and transmission security.
- OCR Enforcement Pattern: The most common HIPAA enforcement actions involve infrastructure failures including unencrypted laptops, unsecured servers, improperly disposed media, and unsecured remote access.

2. Endpoint and Device Governance Under HIPAA

Every device that accesses, stores, or transmits ePHI must be governed under HIPAA physical and technical safeguards:

- ✓ Full disk encryption on all endpoints and portable media containing ePHI. Encrypted devices are a safe harbor under HIPAA breach rules. Unencrypted means mandatory breach reporting.
- ✓ MDM/UEM enrollment required to enforce encryption, screen lock, remote wipe, and application controls on all ePHI-accessing devices.
- ✓ Automatic screen lock after defined inactivity. OCR expects implementation or documented equivalent.
- ✓ Remote wipe capability for all mobile devices and laptops accessing ePHI. Required for device and media controls under 164.310.
- ✓ Secure disposal documentation with certificate of destruction for any hardware that previously stored ePHI.

3. Network Infrastructure Under HIPAA

Network infrastructure must isolate ePHI systems and enforce transmission security:

- ePHI Network Segmentation: Systems storing or processing ePHI must be on isolated network segments. Clinical systems, EHR, and billing systems must not share segments with general office traffic.

- **Encryption in Transit (Required):** All ePHI transmitted over open networks must be encrypted including email, file transfers, and API communications involving patient data.
- **Wireless Security:** Wireless networks providing access to ePHI systems must use strong encryption. Document wireless security configuration.
- **Firewall Controls:** Documented inbound and outbound rules for ePHI network segments with quarterly rule review and logging of all access to ePHI systems.
- **VPN for Remote Access:** Remote access to ePHI systems must be through encrypted VPN with MFA. Unencrypted remote access to ePHI is a technical safeguard violation.

4. Backup and Contingency Infrastructure Under HIPAA

HIPAA Contingency Plan standard (164.308(a)(7)) requires specific infrastructure capabilities:

- **Data Backup Plan (Required):** Establish and implement procedures to create and maintain exact retrievable copies of ePHI. Backup must be current with daily backup for active clinical environments.
- **Disaster Recovery Plan (Required):** Procedures to restore lost data. Must be tested with documented test results and RTO and RPO validation.
- **Emergency Mode Operations Plan (Required):** Procedures to continue critical business processes for protection of ePHI while operating in emergency mode.
- **Testing and Revision (Addressable):** Implement procedures for periodic testing and revision of contingency plans. OCR expects annual documented testing.
- **Offsite Storage:** Backup media must be stored at a separate location from primary systems. Cloud backup with geographic redundancy satisfies this if the vendor has a compliant BAA.

5. Identity and Access Infrastructure Under HIPAA

HIPAA Access Control standard (164.312(a)) requires specific identity and access infrastructure:

- **Unique User Identification (Required):** Every user must have a unique identifier for accessing ePHI systems. Shared accounts are a required safeguard violation that OCR has penalized.
- **Role-Based Access Control:** Users should access only the minimum necessary ePHI for their job function. Configure RBAC in EHR and clinical systems with quarterly role assignment review.
- **Audit Logging (Required):** All access to ePHI systems must be logged including user ID, date, time, action, and data accessed. Logs must be retained for 6 years.

- MFA for Remote Access: Not explicitly required by HIPAA text but OCR has stated MFA is expected for remote ePHI access in the current threat environment.
- Timely Access Termination: Revoke ePHI access on the day of employment termination. Delayed access termination is a common OCR finding.

6. HIPAA Infrastructure Governance Checklist

Infrastructure governance evidence for OCR audit readiness:

- MDM enrollment and encryption compliance report for all ePHI-accessing devices
- Network diagram showing ePHI system segmentation
- Backup and recovery documentation with tested recovery results
- Disaster recovery plan with last test date and RTO and RPO evidence
- Audit log configuration evidence for all ePHI systems
- Access control configuration documentation including RBAC and minimum necessary
- Unique user identification evidence with no shared accounts on ePHI systems
- Device disposal certificates for any hardware previously storing ePHI

NEXT STEP

Build Your Governance Roadmap

Reading this guide is step one. Step two is knowing exactly where your organization stands and what it takes to close the gaps before a regulator does it for you.

Our assessment delivers a prioritized governance roadmap tailored to your regulatory environment.

WHAT THE ASSESSMENT DELIVERS

- ✓ AI usage discovery across your organization
- ✓ Governance gap analysis by regulatory framework
- ✓ Infrastructure and vendor AI risk review
- ✓ Regulatory exposure analysis (SEC, FINRA, HIPAA)
- ✓ Prioritized governance roadmap
- ✓ Board-ready executive summary
- ✓ Regulatory readiness score by framework

Book Your Assessment →

centience.ai/assessments/healthcare

Call us: (877) 945-7177